Acme Corp

AI Agent Security Standard

Document ID: ACME-AIS-2026-01 | Version 1.0 | Classification: Internal
Sample PDF for Traceforce custom risk framework import

1. Purpose

This standard defines the minimum security requirements for AI agents used across Acme Corp. Import into Traceforce as a custom risk framework and map to the default Agent Risk Framework rules and desired states.

2. Scope

Applies to all AI agents (chat, coding, and automation) that process Acme data or connect to Acme systems, including MCP-connected tools used by those agents.

3. Security controls

Numbered controls below are written for the import wizard Extract step (paste this section).

1. Authentication and identity for AI agents

All AI agents that access corporate systems must enforce enterprise single sign-on. Desired state: SSO authentication is required for every agent session; shared API keys and anonymous access are prohibited.

2. Deployment model and hosting environment

AI agents must run only in approved deployment models. Desired state: agents are limited to managed enterprise SaaS or private VPC deployments; unmanaged local installs that exfiltrate corporate data are not permitted without an exception.

3. User activity logging and retention

Organizations must enable comprehensive user activity logging for AI agent usage. Desired state: enable logging of prompts, tool calls, and access events with at least 90-day retention for security review.

4. Data handling and sensitive information

Agents must not process regulated or highly sensitive data unless controls are in place. Desired state: block or redact PII, secrets, and confidential source code from agent prompts unless an approved data classification exception exists.

5. Plugin, extension, and MCP connector allowlisting

Third-party plugins, browser extensions, and MCP servers connected to agents must be allowlisted. Desired state: only approved MCP servers and plugins may be connected; unlisted connectors are denied by default.

6. Network and egress controls

Agent runtime egress must be constrained to approved destinations. Desired state: restrict outbound network access to corporate allowlisted domains and block arbitrary internet egress from agent tooling.

7. Model and plan selection governance

Teams must use approved models and subscription plans. Desired state: only sanctioned enterprise plans and model versions are permitted; consumer or free-tier plans that train on customer data are disallowed.

8. Remediation and incident response for high-risk findings

When a control fails, security must be notified and risk reduced. Desired state: high-risk agent findings are reported as issues and require acknowledgment or enforcement within SLA.

4. Exceptions

Temporary exceptions require security owner approval, compensating controls, and an expiration date not exceeding 90 days.

End of sample document - for demo and QA use only